

מודול 6 — סריקה ומיפוי — תרגילים ופתרונות

חומר לימוד

2 יחידות

תוכן העניינים

1.  תרגילים — מודול 6: סריקה ומיפוי

2.  פתרונות מלאים — מודול 6: סריקה ומיפוי

🎯 תרגילים — מודול 6: סריקה ומיפוי

⚠️ רק על מכונות המעבדה שלך. התקן את **Kioptrix Level 1** (מ-VulnHub) כיעד, באותה רשת-Host Only כמו Kali. פתרונות ב- **solutions.md**.

מקרא רמות: קל ● בינוני ● מתקדם ● אתגר ●

חלק א' — גילוי וסריקה בסיסית (●●)

6.1 ● — גלה אילו מכונות חיות בתת-הרשת של המעבדה (`nmap -sn`). מצא את ה-IP של Kioptrix.

6.2 ● — הרץ סריקת פורטים בסיסית על Kioptrix. אילו פורטים פתוחים?

6.3 ● — הרץ סריקה שמזהה **גרסאות שירותים** ושומרת את הפלט לקובץ. רשום את שרת ה-Web וגרסתו.

6.4 ● — הרץ סריקה של **כל** 65,535 הפורטים. האם התגלה פורט שלא הופיע בסריקה הבסיסית?

חלק ב' — מנייה לפי שירות (●●)

6.5 ● — על פורט 80: הרץ `whatweb` ו-`nikto`. מה הם חשפוי?

6.6 ● — הרץ Directory Brute-Force עם `gobuster` על שרת ה-Web. אילו ספריות/קבצים נסתרים נמצאו?

6.7 ● — על פורט 139/445: הרץ `enum4linux -a`. מה גרסת ה-Samba? אילו שיתופים/משתמשים נחשפו?

6.8 ● — בדוק אם Kioptrix פגיע ל-MS17-010 עם סקריפט ה-NSE המתאים.

חלק ג' — חקר חולשות (● מתקדם)

6.9 — עבור גרסת שרת ה-Web ש-nmap גילה, חפש Exploit עם `searchsploit`. כמה תוצאות? רשום CVE אחד אם מופיע.

6.10 — עבור גרסת ה-Samba/OpenSSH, חפש ב-`searchsploit`. האם קיים Exploit ידוע?

אתגר מסכם — “דוח מנייה מלא של Kioptrix”

הפק מסמך מנייה מסודר (כמו בעבודה אמיתית) הכולל:

1. פרטי היעד: IP, מערכת הפעלה (אם זוהתה).
2. טבלת פורטים: פורט | שירות | גרסה | הערה — לכל פורט פתוח.
3. ממצאי מנייה לכל שירות:
 - HTTP: טכנולוגיות, ספריות נסתרות, ממצאי nikto.
 - SMB: גרסת Samba, שיתופים, פגיעות MS17-010.
4. חולשות פוטנציאליות: לכל שירות — Exploit/CVE שמצאת ב-searchsploit, עם ציון CVSS.
5. מסקנה — וקטור התקיפה: כתוב 2–3 שורות: מהי החולשה המבטיחה ביותר לניצול, ולמה. (זה יהיה הבסיס למודול 7!)

שמור 📁 — במודול 7 ננצל בפועל את החולשה שזיהית כאן.

רשימת בקרה — לפני מעבר למודול 7

- אני מבצע Host Discovery ומזהה מכונות חיות
- אני שולט ב-nmap: פורטים, גרסאות, NSE, שמירת פלט
- אני מְמַנָּה HTTP (nikto, gobuster) ו-SMB (enum4linux)
- אני יודע לבדוק חולשות ידועות (MS17-010, –script vuln)
- אני מחפש Exploits ב-searchsploit ומבין CVE/CVSS
- אני מתעד את הממצאים בצורה מסודרת

פתרונות מלאים: `solutions.md`

פתרונות מלאים — מודול 6: סריקה ומיפוי

נסה לבד ב-missions.md קודם. (הפלט המדויק תלוי בגרסת Kioptrix שלך — הערכים כאן אופייניים ל-Kioptrix Level 1).

חלק א' — גילוי וסריקה בסיסית

6.1

```
nmap -sn 192.168.1.0/24 # התאם לתת-הרשת שלך
```

זוהי את ה-IP שאיננו Kali/Gateway — זהו Kioptrix.

6.2

```
nmap 192.168.1.10
```

פורטים אופייניים ב-Kioptrix 1: **22 (ssh)**, **80 (http)**, **111 (rpcbind)**, **139 (netbios)**, **443 (https)**.

6.3

```
nmap -sV -oN kioptrix_scan.txt 192.168.1.10
```

תוצאה אופיינית: **OpenSSH**, **Apache httpd 1.3.20 ((Unix) mod_ssl/2.8.4 OpenSSL/0.9.6b)**, **Samba 2.9p2**.

6.4

```
nmap -p- 192.168.1.10
```

לעיתים מתגלה פורט Samba גבוה נוסף שלא היה ב-1000 הנפוצים.

חלק ב' — מנייה לפי שירות

6.5

```
whatweb http://192.168.1.10
nikto -h http://192.168.1.10
```

nikto יחשוף לרוב את גרסת **mod_ssl** הפגיעה ואת **OpenSSL 0.9.6b** (חולשה ידועה), וקבצים/הגדרות מיושנים.

6.6

```
gobuster dir -u http://192.168.1.10 -w /usr/share/wordlists/dirb/common.txt
```

תוצאות אופייניות: `./cgi-bin` , `/mrtg` , `/manual` , `/usage`

6.7

```
enum4linux -a 192.168.1.10
```

חושף את גרסת ה-Samba (למשל **Samba 2.2.1a**) — גרסה זו פגיעה ל-Exploit ידוע (trans2open).

6.8

```
nmap -p 445 --script smb-vuln-ms17-010 192.168.1.10
```

ב-1 Kioptrix (לינוקס ישן) לרוב **לא** פגיע ל-MS17-010 (זו חולשת Windows) — אך זהו תרגול חשוב לזהות מתי כן/לא. על מכונת Windows פגיעה, הסקריפט ידווח **VULNERABLE**.

חלק ג' — חקר חולשות

6.9

```
searchsploit apache 1.3.20
searchsploit mod_ssl 2.8
```

ה-Exploit המפורסם: CVE-2002-0082 — **OpenLuck / “OpenFuck” (mod_ssl 2.8.x)**. זהו וקטור הניצול הקלאסי של Kioptrix.

6.10

```
searchsploit samba 2.2
```

קיים Exploit ל-**Samba trans2open** (CVE-2003-0201) — וקטור חלופי להשגת גישה.

6.11 חפש CVE-2002-0082 ב-nvd.nist.gov → ציון CVSS גבוה (Critical). זה מצדיק ניצול מידי.

Kioptrix Level 1 – דוח מנייה

IP: 192.168.1.10 | OS: Linux (Kernel 2.4, Red Hat)

פורטים

פורט	שירות	גרסה	הערה
22	ssh	OpenSSH 2.9p2	ישן
80	http	Apache 1.3.20 + mod_ssl 2.8.4	פגיע
139	smb	Samba 2.2.1a	פגיע (trans2open)
443	https	mod_ssl/OpenSSL 0.9.6b	CVE-2002-0082

מנייה

- HTTP: gobuster מצא /usage,/manual; nikto חשף mod_ssl פגיע
- SMB: enum4linux → Samba 2.2.1a, שיתופים גלויים

חולשות

- CVE-2002-0082 (mod_ssl "OpenFuck") – גבוה CVSS
- CVE-2003-0201 (Samba trans2open) – וקטור חלופי

מסקנה – וקטור תקיפה

root-כ RCE → דרך פורט 443 (CVE-2002-0082) mod_ssl הווקטור המבטיח: ניצול

חלופה: Samba trans2open. שני המסלולים מובילים לשליטה מלאה.

עברת? יש לך וקטור תקיפה ברור. במודול 7 ננצל אותו בפועל. המשך למודול 7.